AOU
الجامعة العربية المفتوحة
Arab Open University
Faculty of Computer Studies

TM256
Cyber Security

Final Examination
Spring Semester 2025/2026

Date: 4/June/2026

AOU EGYPT

Number of Exam Pages: 5 (including this cover sheet)	**Time Allowed: 3 Hours**

Instructions:

- Total Marks: **50**
- This exam consists of **3** parts.
- **ALL questions** must be answered in the External Answer booklet.
- Be sure you write your **name and ID** on the External Answer booklet.
- **A calculator is allowed.**

PART 1: Multiple Choice, True or False questions [15 Marks]

Question 1: Choose the correct answer for the following questions [15 Marks]:

1. What type of attack involves an attacker placing themselves in the flow of traffic between a source and a destination host to transparently monitor, capture, and control network traffic?
   A) Denial of Service (DoS) attack
   B) ARP spoofing
   C) Man-in-the-middle attack
   D) MAC flooding

2. What is network segmentation, and why is it commonly used in network security?
   a) Dividing a network into isolated segments to limit access to certain resources and improve security
   b) Combining multiple networks to allow unrestricted data sharing
   c) Creating multiple firewalls within a single network to restrict traffic
   d) Using virtual machines to simulate different network environments

3. What is the primary goal of code obfuscation?
   A) To prevent reverse-engineering of code
   B) To improve code readability
   C) To speed up the code execution
   D) To reduce the memory usage

4. Which of the following describes the purpose of DevSecOps?
   a) To create isolated networks for different applications
   b) To install firewalls in development environments
   c) To automate security checks, ensuring security is a shared responsibility across development, security, and operations teams
   d) To conduct regular penetration tests only after application deployment

5. What term describes a list of entities that are known to be benign and therefore approved for use in an organization or network?
   A) Whitelist
   B) Blacklist
   C) Access Control List
   D) Essential tasks list

6. In the FAT file system, which component defines the file system and records information about how the volume is set up, such as bytes per sector and sectors per cluster?
   A) File Allocation Table
   B) Root directory
   C) Volume Boot Record (VBR)
   D) Master File Table (MFT)

EXCERPT

7. What term is used to describe a collection of technologies and techniques that examine and identify different types of information that is at rest, in motion, or in use to ensure it conforms to an organization's policy?
   A) Security Information and Event Management (SIEM)
   B) Data Loss Prevention (DLP)
   C) Intrusion Detection System (IDS)
   D) Record Management System (RMS)

8. In business recovery planning, what does the Recovery Time Objective (RTO) represent?
   A) The longest an organization can tolerate the absence of a particular business function.
   B) The time it takes to get critical business functions back up and running once systems are restored.
   C) The extent of data loss that can be tolerated by an organization's critical business systems.
   D) The objective time frame in which the recovery team works to get disrupted systems and resources available once more.

9. In the context of firewalls, which type of firewall examines each packet as it arrives in a stream and looks at other packets in the conversation to gain a picture of the context in which the packets were sent?
   A) Packet filter
   B) Stateless inspection
   C) Stateful packet inspection
   D) Application-level gateway

10. In the context of user tasks and security, requiring users to authenticate themselves before updating a customer record is an example of what type of task?
   A) Production task
   B) Shadow task
   C) Enabling task
   D) Disabling task

11. Which of the following describes instances where security-conscious employees who think they cannot comply with the prescribed security policy create a more fitting alternative to the official mechanisms?
   A) Security fatigue
   B) Shadow security
   C) Conscious incompetence
   D) Permission creep

12. Which piece of metadata indicates a file's unique identifier and specifies the data content of the file, typically occupying the first 20 bytes of the file header?
   A) File extension
   B) MAC times
   C) File signature
   D) Exif data

13. Which type of forensic image captures only the data visible to the device's file system, typically missing deleted files and fragments?
   A) Physical image
   B) Logical image
   C) Bit-for-bit image
   D) Unallocated image

POLEGYPT

14. What is the Master File Table (MFT) in the NTFS file system?
    A) The first sector of a partition that defines the file system.
    B) A database that stores information about all files in a volume, their locations, and associated metadata.
    C) A left-over storage area within an allocated cluster.
    D) Space that is available but not actively used and invisible to the OS.

15. What is the role of a hardware write blocker in digital forensics?
    A) It connects two computers over a network to copy files seamlessly.
    B) It permanently encrypts the original data on the suspect's device to prevent tampering.
    C) It physically sits between a device and collection media to allow data reading without sending any write signals to the device.
    D) It calculates MD5 and SHA1 hashes of the examiner's reports.

PART 2: Short Questions [16 Marks]

Question 2: Given the following open-ended questions that require short answers:

A. How does Mandatory Access Control (MAC) differ from Discretionary Access Control (DAC)? [2 Marks]
B. How does “steganography” differ from standard encryption? [2 Marks]
C. Explain the primary principle of "Role-Based Access Control" (RBAC). [2 Marks]
D. Briefly explain the concept of network segmentation and its purpose. [2 Marks]
E. What role do signatures play in antivirus systems? [2 Marks]
F. What are some popular techniques for mitigating wireless networks? [3 Marks]
G. Briefly explain the goal of “fuzzing” in software security testing. [3 Marks]

PART 3: Problem questions [19 Marks]

Question 3: Alice wants to use the RSA algorithm to encrypt a message. She chooses two prime numbers, p = 3 and q = 17. By using these prime numbers, compute the following components to generate the public and private keys. [6 Marks]

1. The modulus n
2. Euler’s totient $\varphi(n)$.
3. Choose a public key exponent *e*
4. Compute the private key exponent *d*
5. Write the public and the private keys.

Question 4: Human Factors (Root Cause & Shadow Security). [6 Marks]

A corporate audit reveals a massive security violation: 60% of the sales team has been bypassing the company’s secure, encrypted file-transfer application. Instead, they are using personal Dropbox accounts to share sensitive client contracts with external

AOU EXAM

partners. When questioned, employees stated, *"The secure portal requires a VPN login, a physical token code, and takes 5 minutes to upload a single PDF. I lose clients waiting for it*". Using the concepts of "Shadow Security", "Production Tasks", and "Enabling Tasks", diagnose the root cause of this security failure. Also, formulate a three-step strategy for the Security Manager to resolve this issue that does not rely on simply punishing the employees or blindly blocking Dropbox.

Question 5: Web Application Threats. [7 Marks]
A user logs into their favorite eCommerce website to check the status of a recent order. The eCommerce application authenticates the user and establishes a connection. Without logging out, the user opens a new browser tab to check their personal email. They see an email offering a "Free Gift" and click the link. The link opens a blank web page, so the user closes it, assuming it is broken. Ten minutes later, the user receives an email confirmation from the eCommerce website thanking them for a large, expensive purchase that they did not make.

1. Identify the specific type of application attack that occurred.
2. Write out the step-by-step logical flow of how the attacker successfully forced the eCommerce site to process this unauthorized purchase. Explicitly describe the role of the victim's web browser, the HTTP request, and why the eCommerce site accepted the forged command without a password.
3. State two specific actions the user could have taken to prevent this.

End of questions

AOU EGYPT